What is a baseline, and why does knowing what is normal matter for a SOC analyst?

1. **Definition of Baseline**

A baseline is a documented representation of normal behavior for a user, system, application, or network over a specific period.

It is established by collecting and analyzing historical activity to understand expected patterns. A baseline may include:

- Normal login times.
- Typical network traffic volumes.
- Commonly accessed applications.
- Average CPU and memory usage.
- Regular DNS query patterns.
- Expected authentication failures.
- Normal administrative activities.
- Common communication destinations.

2. **Examples of Baselines**

Activity	Normal Baseline	Possible Anomaly
Login activity	Employee signs in during normal office hours	Login at an unusual time from an unfamiliar device
Network traffic	Workstation transfers around 1 GB per day	Sudden transfer of 40 GB
DNS activity	Device queries expected business domains	Thousands of random-looking domain queries
CPU usage	Server normally operates at 20–40% utilization	Unexpected sustained 100% CPU usage
Authentication	Few failed login attempts	Hundreds of failures within minutes
Administrative access	Administrator accesses designated servers	Administrative access to unusual systems

These values are illustrative. Real baselines depend on the organization's environment.

3. **Importance of Baselines**

   a. **Anomaly Detection:** Baselines help identify deviations from normal behavior that may indicate security threats.

   b. **Reduction of False Positives:** Expected administrative activities, scheduled jobs, and regular traffic patterns can be distinguished from genuinely unusual behavior.

c. **Early Threat Detection:** Sudden changes in authentication, process execution, or network communication can reveal potential compromises.

d. **Threat Hunting:** Security analysts use historical patterns to identify suspicious activity that may not trigger traditional signature-based alerts.

e. **Incident Investigation:** Baselines help determine when abnormal behavior started and how it differs from previous activity.

f. **Alert Prioritization:** Alerts involving significant deviations from normal behavior can receive greater investigative attention when supported by asset criticality and other evidence.

4. **Types of Security Baselines**

Baseline Type	Description
Network Baseline	Normal traffic volumes, protocols, ports, and communication patterns
User Behaviour Baseline	Typical login times, devices, locations, and access patterns
System Baseline	Expected processes, services, resource usage, and configurations
Application Baseline	Normal application requests, performance, and error rates
Authentication Baseline	Typical successful and failed login patterns
Security Configuration Baseline	Approved system settings, permissions, and security controls

5. **Baseline Monitoring Process**
   a. **Collect historical data**: Logs, network traffic, authentication and system activity
   b. **Establish normal patterns:** Identify expected activity by user, device and time
   c. **Monitor current activity:** Continuously collect and analyze new events
   d. **Compare against baseline:** Identify significant deviations from expected behavior
   e. **Investigate anomalies:** Correlate evidence and determine possible causes
   f. **Update the baseline:** Account for legitimate operational and environmental changes

6. **Challenges in Baseline Monitoring**

- Changing environments: New applications, devices, and work schedules change normal activity.
- False positives: Legitimate unusual activity may be flagged as suspicious.
- False negatives: Malicious activity may resemble normal behavior.
- Insufficient data: A short observation period may not represent normal operations accurately.
- Baseline poisoning: If malicious activity is included in training data, it may incorrectly become part of the expected behavior.

Therefore, baselines should be regularly reviewed and updated using trustworthy data.